



13. Hafta

SIZMA TESTLERİ(PENTEST)VE SİBER GÜVENLİK STANDARTLARI

Sızma Testi

- Penetration Test
- PenTest
- Sızma Testi
- Yazılım Güvenlik Testi
- Siber Güvenlik Tatbikatı
- Siber Tatbikat

gibi isimlerle de anılmaktadır.

Sızma Testi

Güvenlik uzmanları tarafından gerçekleştirilen, kötü amaçlı bir saldırganın sisteme verebileceği zararları raporlamak ve önceden savunma önlemleri almak amacı ile oluşturulan saldırı denemelerinin tamamıdır. (Burlu, 2010)

Sızma testlerinin amacı, kuruluşlara sistemlerini daha güvenli hale getirmelerinde yardımcı olmaktır.

Sızma Testleri

- Beyaz şapkalı hacker,
- Etik hacker,
- Pentester,
- Sızma Testi Uzmanı,

gibi isimler adı altında ifade edilen siber güvenlik uzmanları tarafından gerçekleştirilmektedir.

Uzmanlar belirli kalite standartlarına göre çalışmaktadırlar.

Sızma Testi = Zafiyet Analizi **mi?**

- Sızma Testi **≠** Zafiyet Analizi
- Aynı şey değildir.
- Sızma testi, yazılım ve yöntemler kullanarak hedef sistemlere sızma girişimleridir.
- Zafiyet Analizi, otomatize araçlar kullanarak sistem güvenliğinin teknik açıdan incelenmesi ve raporlanmasıdır.

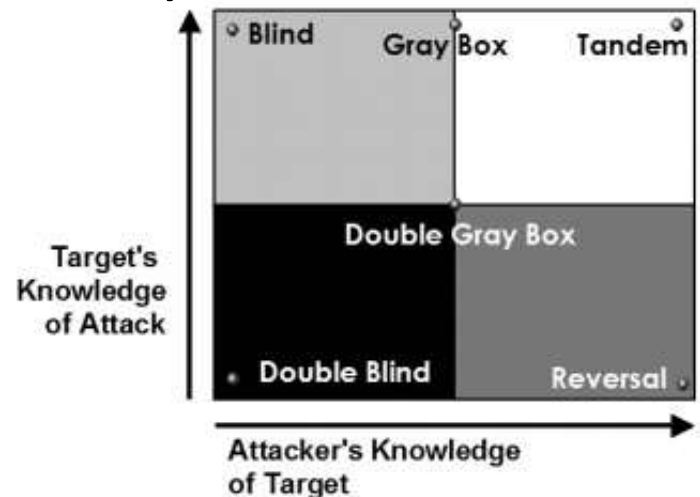
Zafiyetten > Sızma Testine

- Belirlenen bilişim sistemlerindeki mantık hataları ve zafiyetleri tespit ederek, söz konusu güvenlik açıklıklarının kötü niyetli kişiler tarafından istismar edilmesini önlemek ve sistemleri daha güvenli hale getirmek maksadıyla, “yetkili” kişiler tarafından ve “yasal” olarak gerçekleştirilen güvenlik testleridir.
- Pentest çalışmalarındaki asıl amaç, zafiyeti tespit etmekten öte ilgili zafiyeti sisteme zarar vermeyecek şekilde istismar etmek ve yetkili erişimler elde etmektir.

Sızma Testi Yöntemleri

- Hedefe yapılacak testin türü uzmana verilecek yetki ve bilgiye göre değişiklik göstermektedir.
- Beyaz Kutu Sızma Testleri (White Box)
- Siyah Kutu Sızma Testleri (Black Box)
- Gri Kutu Sızma Testleri (Gray Box)

Şeklinde üç gruba ayırmak mümkündür.



Beyaz Kutu

- Güvenlik testi ekibi, sistemin kendisi ve arka planda çalışan ilave teknolojiler hakkında tam bilgi sahibidir.
- Test yapılan Firmaya daha büyük fayda sağlar.
- Hata ve zafiyetleri bulmak kolaylaşacağından bunlara tedbir alınma süresi de azalacaktır.
- Sistemin zarar görme riski çok azdır ve maliyet olarak da en az maliyetli olandır.

Siyah Kutu

- Başlangıçta güvenlik testi yapılacak sistemle ilgili bir bilgi yoktur.
- Tamamen bilinmeyen bir sistem ile ilgili bilgi toplanacak ve testler yapılacaktır.
- Bu yöntemde test ekibinin sistem ile ilgili bilgi düzeyi hiç olmadığından, yanlışlıkla sisteme zarar verme ihtimalleri de yüksektir.
- Bilgi toplama safhası oldukça zaman alır.
- Süre bakımından en uzun süren yaklaşım tarzıdır.

Gri Kutu

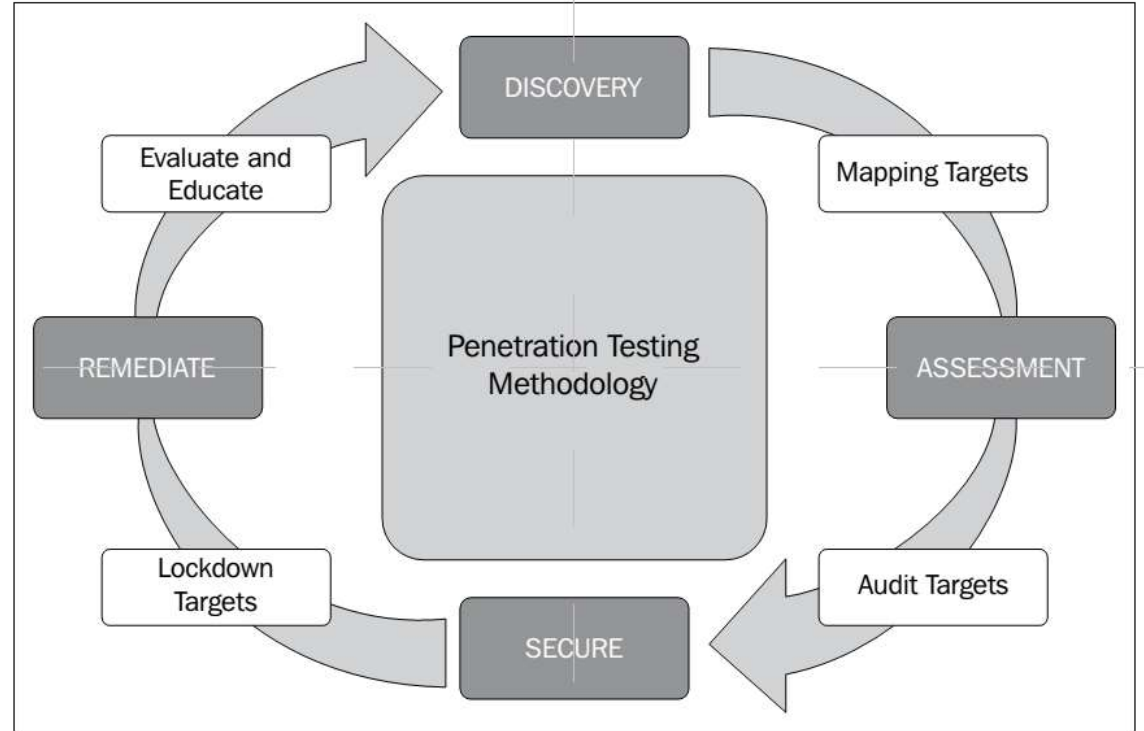
- Sistem ile ilgili bilgiler mevcuttur.
- *Örneğin; IP adres listesi, sunucu sistem ile ilgili versiyon bilgisi vb.*
- Bilgiler güvenlik testi yapacak ekibe önceden sağlanır.
- Black Box yaklaşımına göre daha kısa zaman alır.
- Kontrolü ve testi istenen IP adresleri belli olduğundan sistemin, istem dışı zarar görme ihtimali de azalmış olur.

Metodoloji

- Önceden belirlenmiş ve denenmiş, kalıplaşmış standartlar haline gelmiş kural veyöntemler.
- **OWASP** (Open Web Application Project)
- **OSSTIMM** (The Open Source Security Testing Methodology Manual)
- **ISSAF** (Information Systems Security Assessment Framework)
- **NIST** (SP800-15)

Sızma Testi Metodolojisi

- Bilgi toplama
- Ağ Haritalama
- Zayıflık Tarama
- Sisteme Sızma
- Yetki Yükseltme
- Başka Ağlara Sızma
- Erişimleri Koruma
- İzleri Temizleme
- Raporlama



Kapsam Belirleme, Bilgi Toplama, Keşif ve Tarama, Zafiyet Taraması ve Analizi, İstismar Etme, Yetki Yükseltme, Yayılma, Bilgi-Doküman Toplama, İzleri Temizleme, Raporlama



Sızma Testi Çeşitleri

- İç Ağ
- Dış Ağ
- Web
- Kablosuz
- Mobil
- Sosyal Mühendislik
- Dos/DDoS



**DIŞ AĞ
SIZMA TESTİ**



**İÇ AĞ
SIZMA TESTİ**



**WEB UYGULAMA
SIZMA TESTİ**



**KABLOSUZ AĞ
SIZMA TESTİ**



**MOBİL UYGULAMA
SIZMA TESTİ**



**SOSYAL
MÜHENDİSLİK**



**DOS/DDOS VE
PERFORMANS
TESTLERİ**

Pentest Rapor Örnekleri

1. <https://www.offensive-security.com/reports/sample-penetration-testing-report.pdf>
2. <https://www.sans.org/reading-room/whitepapers/bestprac/writing-penetration-testing-report-33343>
3. http://www.niiconsulting.com/services/security-assessment/NII_Sample_PT_Report.pdf



Professional Information Security Training and Services

OFFENSIVE security

www.offensive-security.com

Penetration Test Report

MegaCorp One

August 10th, 2013

Offensive Security Services, LLC

19706 One Norman Blvd.
Suite B #253
Cornelius, NC 28031
United States of America

Tel: 1-402-608-1337
Fax: 1-704-625-3787
Email: info@offsec.com
Web: <http://www.offensive-security.com>



Interested in learning more about security?

SANS Institute InfoSec Reading Room

This paper is from the SANS Institute Reading Room site. Reposting is not permitted without express written permission.

Writing a Penetration Testing Report

Writing a penetration testing report is an art that needs to be learned to make sure that the report has delivered the right message to the right people. The report will be sent to the target organization's senior management and technical team as well. For this reason, we, as penetration testers, need to deliver the report in a way that serves our objective to secure the information. This paper will explain the penetration testing report writing methodology, based on the author's experiences, describing the report...

Copyright SANS Institute
Author Retains Full Rights

Build your business' breach action plan. **START NOW**



LifeLock is a registered trademark of LifeLock, Inc. © 2013. All rights reserved. LifeLock, the LifeLock logo, and the LifeLock tagline are trademarks of LifeLock, Inc.

Penetration Testing Report



For
<>
From



NII
Consulting
www.niiconsulting.com

ATTENTION: This document contains information from NII that is confidential and privileged. The information is intended for the private use of <>. By accepting this document you agree to keep the contents in confidence and not copy, disclose, or distribute this without written request to and written confirmation from NII. If you are not the intended recipient, be aware that any disclosure, copying, or distribution of the contents of this document is prohibited.

Standartları Oluşturan Kuruluşlar

- IEEE
- ICANN
- ISO/IEC
- ETSI
- IETF
- NIST
- PCI SSC
- TSE

Standartlar

- ISO 27001:2013 Bilgi Güvenliği Yönetim Sistemi
- CC
- COBIT
- COSO
- ITIL
- CMMI
- TSE

ISO 27001

- Varlıkların sınıflandırılması,
 - Gizlilik, bütünlük ve erişebilirlik kriterlerine göre varlıkların değerlendirilmesi,
 - Risk analizi yapılması,
 - Risk analizi çıktılarına göre uygulanacak kontrollerin belirlenmesi,
 - Dokümantasyon oluşturulması,
 - Kontrollerin uygulanması,
 - İç tetkik,
 - Kayıtların tutulması,
 - Yönetimin gözden geçirmesi,
 - Belgelendirme
- şeklindedir.

Sertifikalar

- CompTIA – Security+
- **CEH** (Certified Ethical Hacker)
- **LPT** (Licensed Penetration Tester)
- **OSCP** (Offensive Security Certified Professional)
- **CCSP** (Cisco Certified Security)
- **CISSP** (Certified Information Systems Security Professional)
- CPTe (Certified Penetration Testing Engineer)
- ECSA (EC-Council Certified Security Analyst)
- GIAC (GPEN, GWAPT, GXPn)
- CEPT (Certified Expert Penetration Tester)



Windows Pentest Box

- Windows ile Pentest araçları
- <https://pentestbox.org>



cmd.exe

C:\Users\Aditya Agrawal\Desktop

> nmap

cmd.exe

C:\Users\Aditya Agrawal\Desktop

> ncat

cmd.exe

C:\Users\Aditya Agrawal\Desktop

> ndiff

cmd.exe

C:\Users\Aditya Agrawal\Desktop

> nping